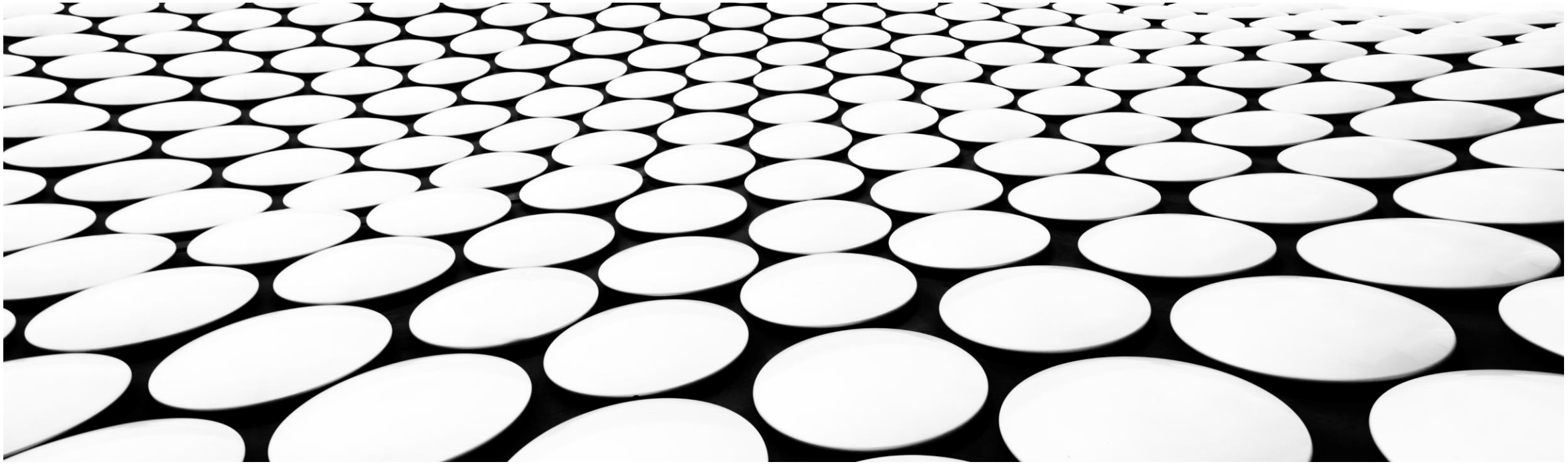


© Copyright 2025 – Donnacha Forde. All rights reserved.

Tour de Cybersecurity

AI-Native Security

Donnacha Forde



© Copyright 2025 – Donnacha Forde. All rights reserved.

$whoami

- Developer
- Architect
- Manager
- Technical Director
- Technology Strategist



Mostly Finance (~10yrs)

Mostly Systems-Management (~15yrs)

Security (~10 yrs)

© Copyright 2025 – Donnacha Forde. All rights reserved.



© Copyright 2025 – Donnacha Forde. All rights reserved.

AGENDA

- Why is this important?
- How did we get here?
- Detection is Key
- AI in Cybersecurity

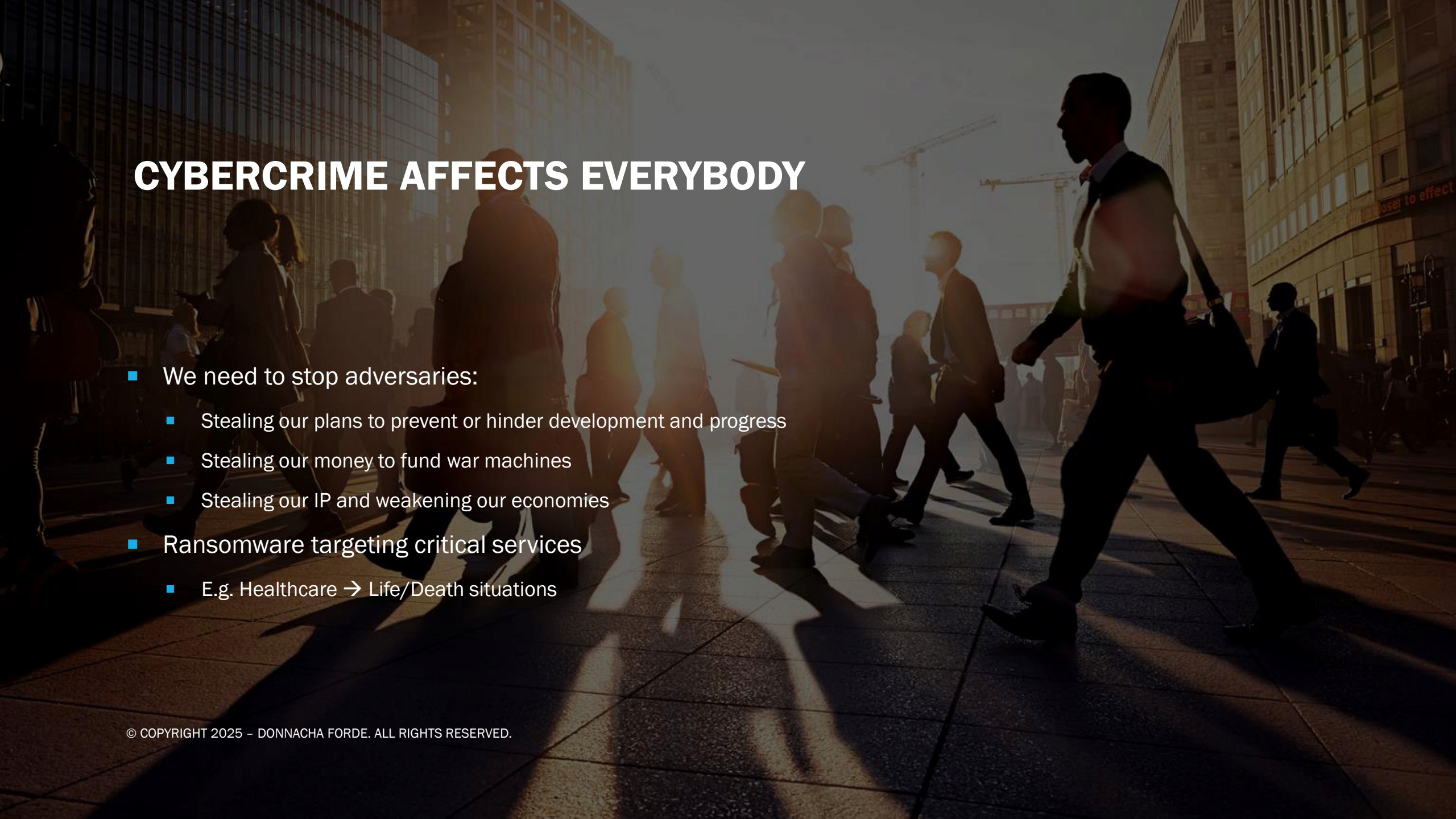


© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.



Why is this important?

© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.



CYBERCRIME AFFECTS EVERYBODY

- We need to stop adversaries:
  - Stealing our plans to prevent or hinder development and progress
  - Stealing our money to fund war machines
  - Stealing our IP and weakening our economies
- Ransomware targeting critical services
  - E.g. Healthcare → Life/Death situations

© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

COSTS OF CYBERCRIME

Estimated cost globally

- 2021 → > **$6 Trillion**
- 2022 → > **$8 Trillion**
- 2023 → > **$11 Trillion**
- 2026 → $20 Trillion*

World's 3rd largest economy (after USA and China)

Doubled since 2015

Almost doubled again since 2021

Context

- More profitable than Global Trade in Illegal Drugs
- Costs are greater costs than the damage from natural disasters
- Cybercrime represents the greatest transfer of economic wealth in history

Source: https://www.evolvesecurity.com/blog-posts/actual-cost-of-cybercrime

Source: https://cybersecurityventures.com/hackerpocalypse-cybercrime-report-2016

© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

*estimated

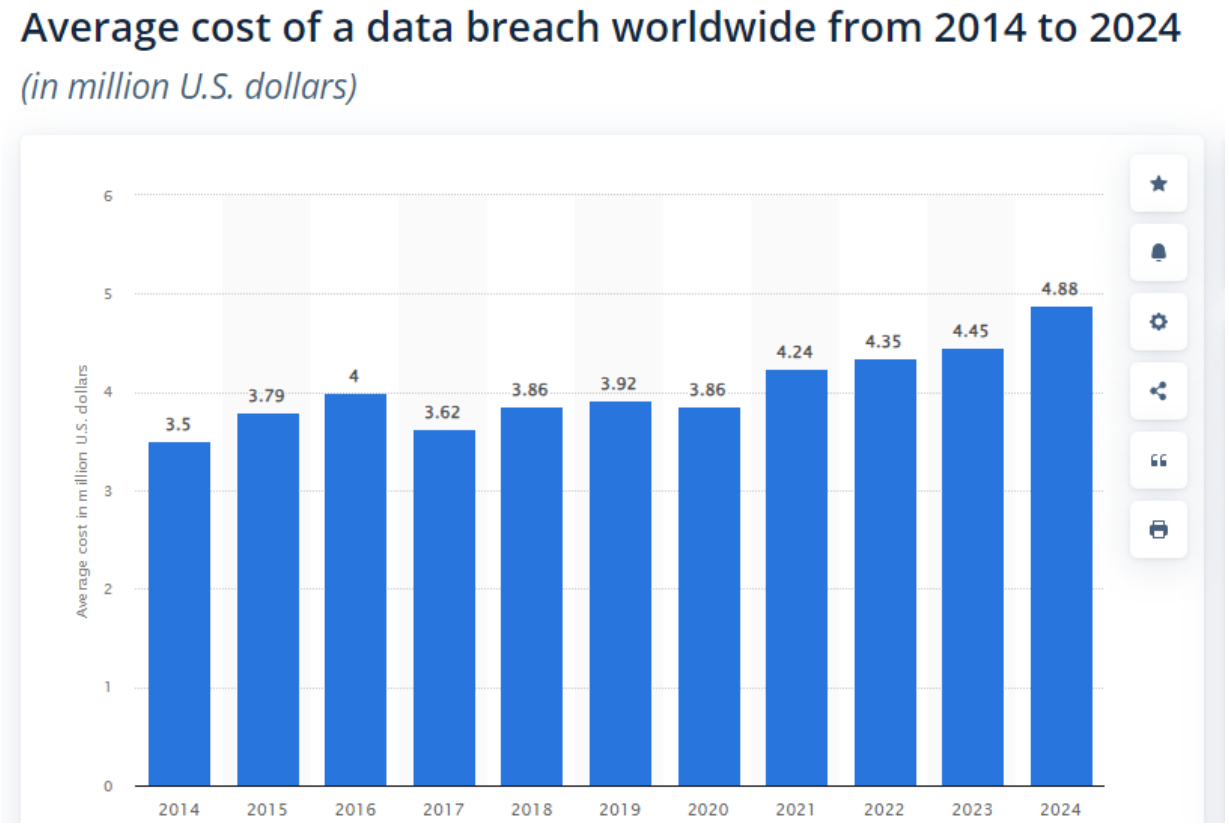


Costs of Data Breaches

- Data Breach Costs
  - Average cost of data breach – all sectors: $4.88M
    - (10% increase over 2023)
  - Average cost of data breach in the financial sector: $6.08M
    - (3% increase over 2023)

- Estimated 70% of successful data breaches **originate at the endpoint**

Source: https://www.evolvesecurity.com/blog-posts/actual-cost-of-cybercrime



Source: https://www.statista.com/statistics/987474/global-average-cost-data-breach

© Copyright 2025 – Donnacha Forde. All rights reserved.

Who are our Adversaries?

Top three threats



Organized Crime

Criminal gangs

Financially motivated

Often state sponsored or state sanctioned



Nation-state

Political/Financial motives



Hacktivism

Access Data

Disruption

Exposure

© Copyright 2025 – Donnacha Forde. All rights reserved.



Famous Chollima



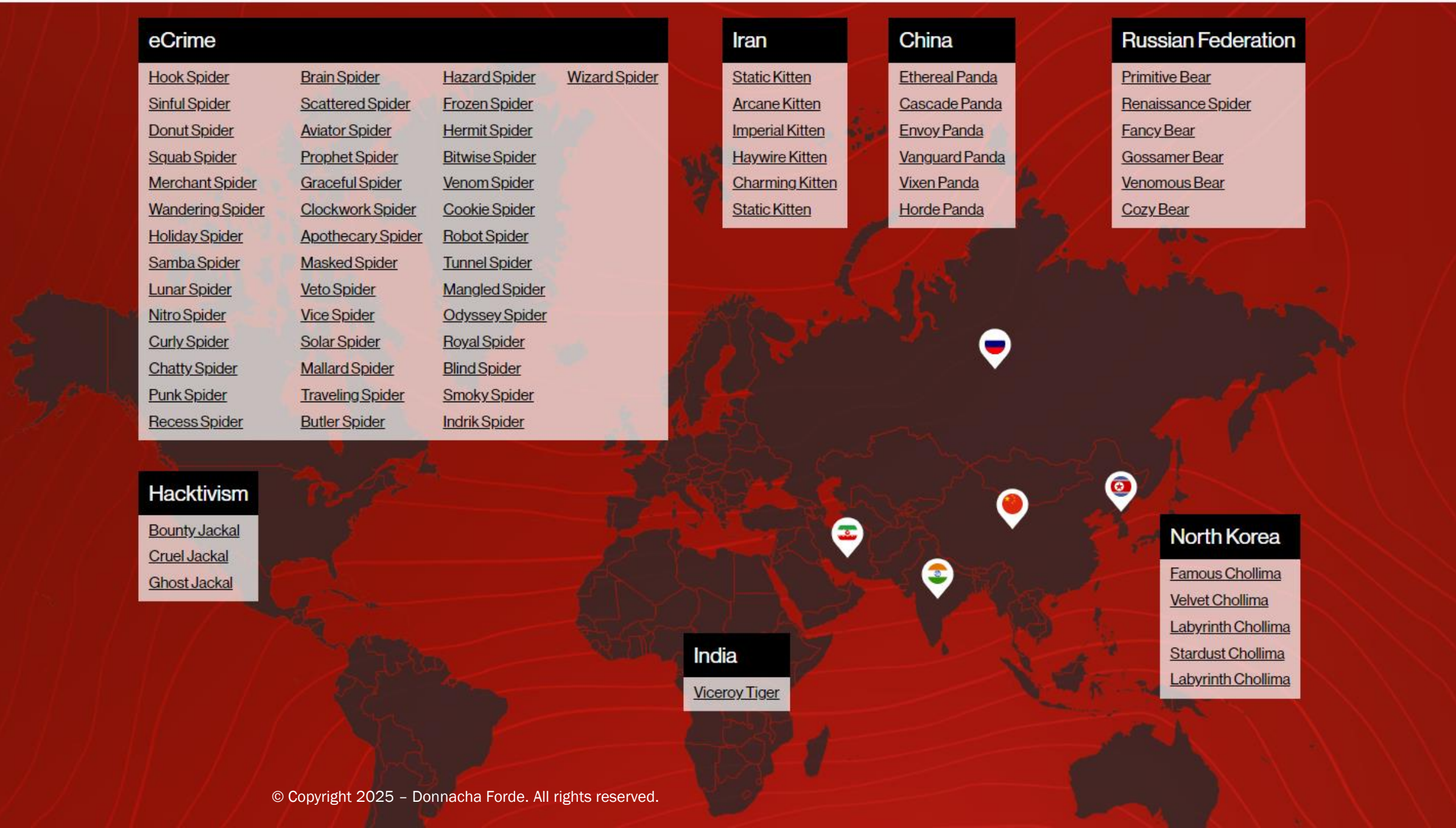
Punk Spider



Horde Panda

© Copyright 2025 – Donnacha Forde. All rights reserved.

Global Threat Landscape



eCrime

Hook Spider	Brain Spider	Hazard Spider	Wizard Spider
Sinful Spider	Scattered Spider	Frozen Spider	
Donut Spider	Aviator Spider	Hermit Spider	
Squab Spider	Prophet Spider	Bitwise Spider	
Merchant Spider	Graceful Spider	Venom Spider	
Wandering Spider	Clockwork Spider	Cookie Spider	
Holiday Spider	Apothecary Spider	Robot Spider	
Samba Spider	Masked Spider	Tunnel Spider	
Lunar Spider	Veto Spider	Mangled Spider	
Nitro Spider	Vice Spider	Odyssey Spider	
Curly Spider	Solar Spider	Royal Spider	
Chatty Spider	Mallard Spider	Blind Spider	
Punk Spider	Traveling Spider	Smoky Spider	
Recess Spider	Butler Spider	Indrik Spider	

Iran

- Static Kitten
- Arcane Kitten
- Imperial Kitten
- Haywire Kitten
- Charming Kitten
- Static Kitten

China

- Ethereal Panda
- Cascade Panda
- Envoy Panda
- Vanguard Panda
- Vixen Panda
- Horde Panda

Russian Federation

- Primitive Bear
- Renaissance Spider
- Fancy Bear
- Gossamer Bear
- Venomous Bear
- Cozy Bear

Hacktivism

- Bounty Jackal
- Cruel Jackal
- Ghost Jackal

India

- Viceroy Tiger

North Korea

- Famous Chollima
- Velvet Chollima
- Labyrinth Chollima
- Stardust Chollima
- Labyrinth Chollima

© Copyright 2025 – Donnacha Forde. All rights reserved.

ATT&CKcon 6.0 returns October 14-15, 2025 in McLean, VA. More details about tickets and our CFP can be found here

ATT&CK®

Get Started | Take a Tour

Contribute | Blog

FAQ | Random Page

MITRE ATT&CK® is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community.

With the creation of ATT&CK, MITRE is fulfilling its mission to solve problems for a safer world — by bringing communities together to develop more effective cybersecurity. ATT&CK is open and available to any person or organization for use at no charge.

ATT&CK Matrix for Enterprise

layout: side | show sub-techniques | hide sub-techniques

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
10 techniques	8 techniques	10 techniques	14 techniques	20 techniques	14 techniques	44 techniques	17 techniques	32 techniques	9 techniques	17 techniques	18 techniques	9 techniques	14 techniques
Active Scanning (3)	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation (7)	Abuse Elevation Control Mechanism (6)	Abuse Elevation Control Mechanism (6)	Adversary-in-the-Middle (4)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (4)	Application Layer Protocol (5)	Automated Exfiltration (1)	Account Access Removal
Gather Victim Host Information (4)	Acquire Infrastructure (8)	Drive-by Compromise	Command and Scripting Interpreter (11)	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction (1)
Gather Victim Identity Information (3)	Compromise Accounts (3)	Exploit Public-Facing Application	Container Administration Command	Boot or Logon Autostart Execution (14)	Account Manipulation (7)	BITS Jobs	Credentials from Password Stores (6)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection	Exfiltration Over Alternative Protocol (3)	Data Encrypted for Impact
Gather Victim Network Information (6)	Compromise Infrastructure (8)	External Remote Services	Deploy Container	Boot or Logon Initialization Scripts (5)	Boot or Logon Autostart Execution (14)	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (2)	Automated Collection	Data Encoding (2)	Exfiltration Over C2 Channel	Data Manipulation (3)
Gather Victim Org Information (4)	Develop Capabilities (4)	Hardware Additions	Exploitation for Client Execution	Browser Extensions	Boot or Logon Initialization Scripts (5)	Debugger Evasion	Forced Authentication	Cloud Service Dashboard	Remote Services (8)	Browser Session Hijacking	Data Obfuscation (3)	Exfiltration Over Other Network Medium (1)	Defacement (2)
Phishing for Information (4)	Establish Accounts (3)	Phishing (4)	Inter-Process Communication (3)	Compromise Host Software Binary	Create or Modify System Process (5)	Deobfuscate/Decode Files or Information	Forge Web Credentials (2)	Cloud Service Discovery	Replication Through Removable Media	Clipboard Data	Dynamic Resolution (3)	Exfiltration Over Physical Medium (1)	Disk Wipe (2)
Search Closed Sources (2)	Obtain Capabilities (7)	Replication Through Removable Media	Native API	Create Account (3)	Domain or Tenant Policy Modification (2)	Deploy Container	Input Capture (4)	Cloud Storage Object Discovery	Software Deployment Tools	Data from Cloud Storage	Encrypted Channel (2)	Exfiltration Over Web Service (4)	Endpoint Denial of Service (4)
Search Open Technical Databases (5)	Stage Capabilities (6)	Supply Chain Compromise (3)	Scheduled Task/Job (5)	Create or Modify System Process (5)	Escape to Host	Direct Volume Access	Modify Authentication Process (9)	Container and Resource Discovery	Taint Shared Content	Data from Configuration Repository (2)	Fallback Channels	Scheduled Transfer	Financial Theft
Search Open Websites/Domains (3)		Trusted Relationship	Serverless Execution	Event Triggered Execution (17)	Event Triggered Execution (17)	Domain or Tenant Policy Modification (2)	Multi-Factor Authentication Interception	Debugger Evasion	Use Alternate Authentication Material (4)	Data from Information Repositories (5)	Hide Infrastructure	Transfer Data to Cloud Account	Firmware Corruption
Search Victim-Owned Websites		Valid Accounts (4)	Shared Modules	External Remote Services	Exploitation for Privilege Escalation	Execution Guardrails (2)	Multi-Factor Authentication Request Generation	Device Driver Discovery		Data from Local System	Ingress Tool Transfer		Inhibit System Recovery
			Software Deployment Tools	Hijack Execution Flow (13)	Hijack Execution Flow (13)	Exploitation for Defense Evasion	Network Sniffing	Domain Trust Discovery		Data from Network Shared Drive	Multi-Stage Channels		Network Denial of Service (2)
			System Services (2)	Implant Internal Image	Process Injection (12)	File and Directory Permissions Modification (2)	OS Credential Dumping (8)	File and Directory Discovery		Data from Removable Media	Non-Application Layer Protocol		Resource Hijacking (4)
			User Execution (3)	Modify Authentication Process (9)	Scheduled Task/Job (5)	Hide Artifacts (12)	Steal Application Access Token	Group Policy Discovery		Data Staged (2)	Non-Standard Port		Service Stop
			Windows Management Instrumentation	Office Application Startup (6)	Valid Accounts (4)	Hijack Execution Flow (13)	Steal or Forge Authentication Certificates	Log Enumeration		Email Collection (3)	Protocol Tunneling		System Shutdown/Reboot
				Power Settings		Impair Defenses (11)	Steal or Forge Kerberos Tickets (5)	Network Service Discovery		Input Capture (4)	Proxy (4)		
				Pre-OS Boot (5)		Impersonation	Steal Web Session Cookie	Network Share Discovery		Screen Capture	Remote Access Software		
				Scheduled Task/Job (5)		Indicator Removal (10)	Unsecured Credentials (8)	Network Sniffing		Video Capture	Traffic Signaling (2)		
				Server Software Component (5)		Indirect Command Execution		Password Policy Discovery			Web Service (3)		
				Traffic Signaling (2)		Masquerading (10)		Peripheral Device Discovery					
				Valid Accounts (4)		Modify Authentication Process (9)		Permission Groups Discovery (3)					
						Modify Cloud Compute Infrastructure (5)		Process Discovery					
						Modify Cloud Resource Hierarchy		Query Registry					
						Modify Registry		Remote System Discovery					
						Modify System Image (2)		Software Discovery (1)					
						Network Boundary Bridging		System Information Discovery					
								System Location Discovery (1)					
								System Network Configuration Discovery (2)					

Modern attacks demand a modern defense

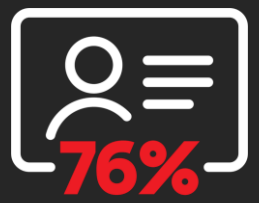
Accelerating attack times



62 min.

Avg eCrime breakout time

Growing access broker ads



YoY growth in victims named on eCrime dedicated leak sites

Rising cross-domain proficiency



YoY increase in cloud environment intrusions

Persistent Pain Points for Security Teams

7 in 10

Organizations struggle to keep up with alerts

Need to respond faster and at scale

50 Tools

Avg. operated by modern security teams

Need to protect cross-domain attack surfaces

64%

Leaders report rising turnover among security staff

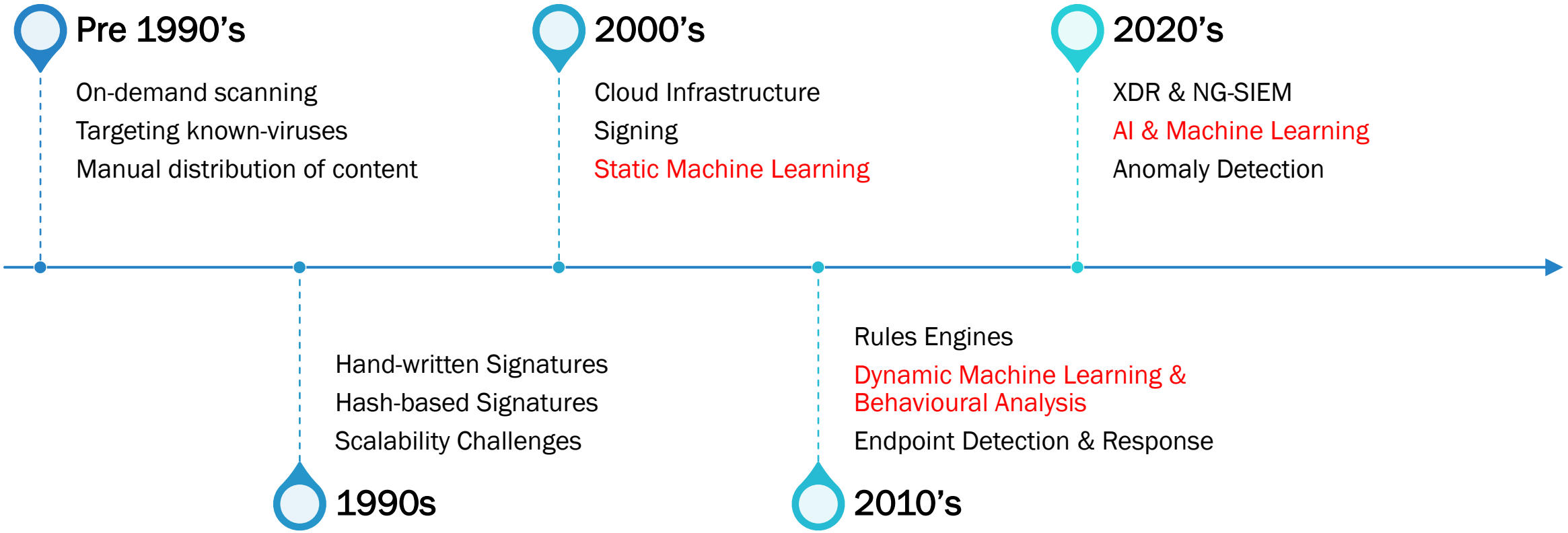
Need to quickly enable security staff of all levels

® CrowdStrike, Inc. All Rights Reserved

How did we get here?

© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

THE EVOLUTION OF ANTIMALWARE

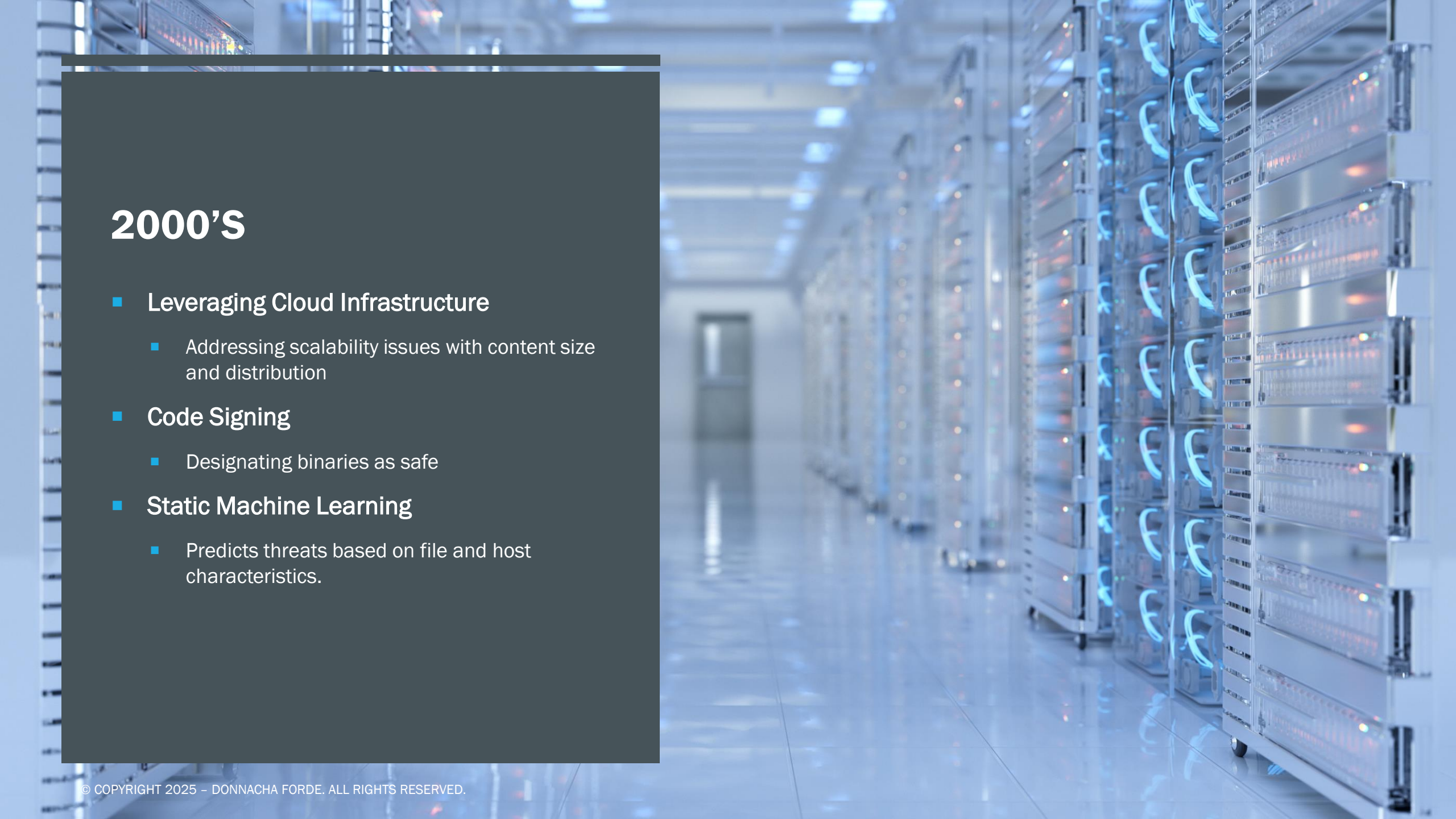


© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

PRE 1990'S AND 1990'S

- Signature-based detection
  - Scanned files for known malware signatures/matching patterns.
- Hash-Based Detection
  - Quick identification via file hashes.

© COPYRIGHT 2025 DONNACHA FORDE. ALL RIGHTS RESERVED.



2000’S

- Leveraging Cloud Infrastructure
  - Addressing scalability issues with content size and distribution
- Code Signing
  - Designating binaries as safe
- Static Machine Learning
  - Predicts threats based on file and host characteristics.

© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

2010’S

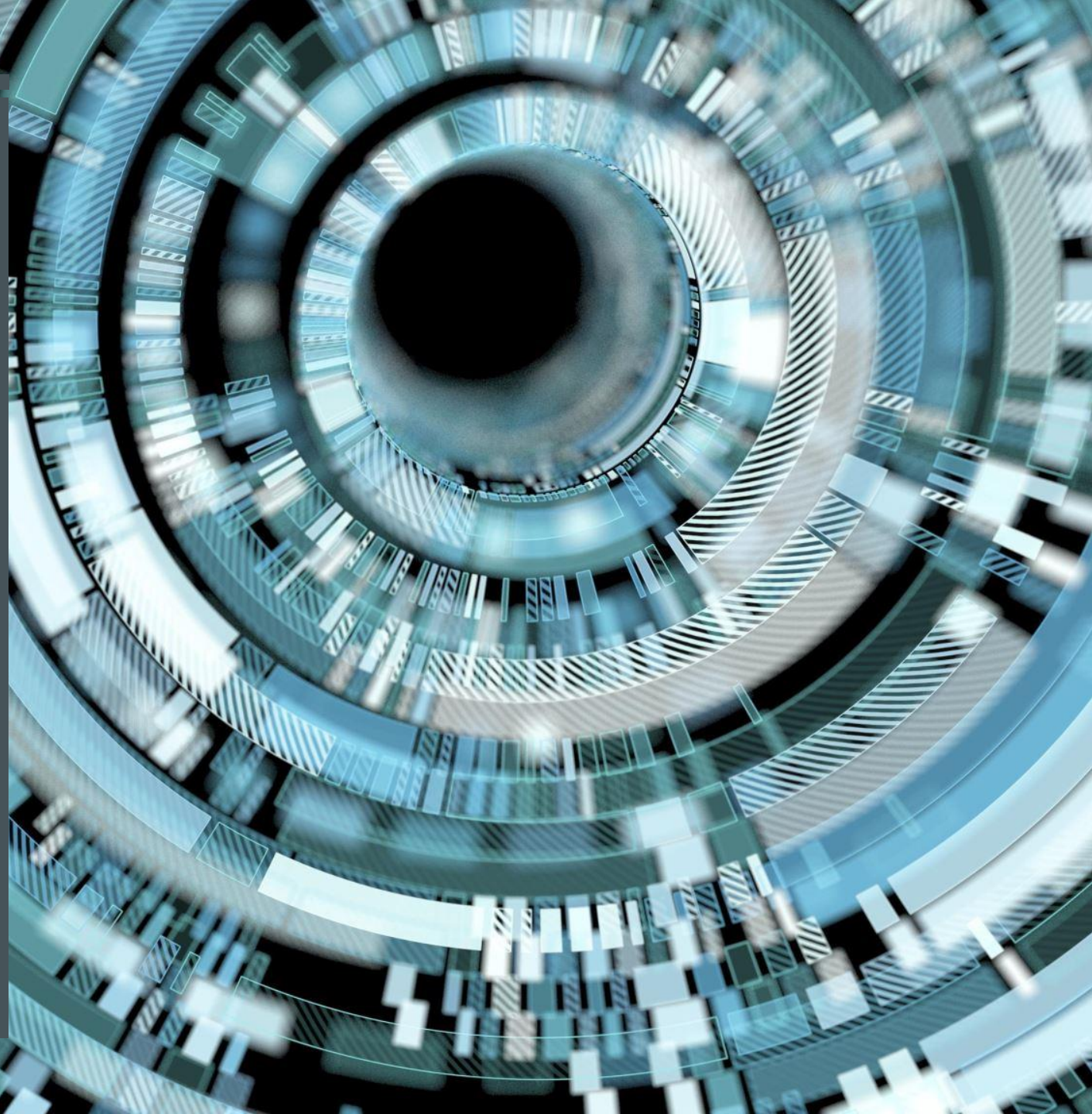
- Endpoint Detection & Response (EDR)
  - Shift of emphasis to Detection
- Dynamic Machine Learning & Behavioral Analysis
  - Predicts threats based on run-time characteristics



© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

2020’S

- XDR & NG-SIEM
  - Improved detection using multi-source event correlation
- AI identifies deviations from normal behavior patterns.
- AI used by analysts to cope with volume of alerts

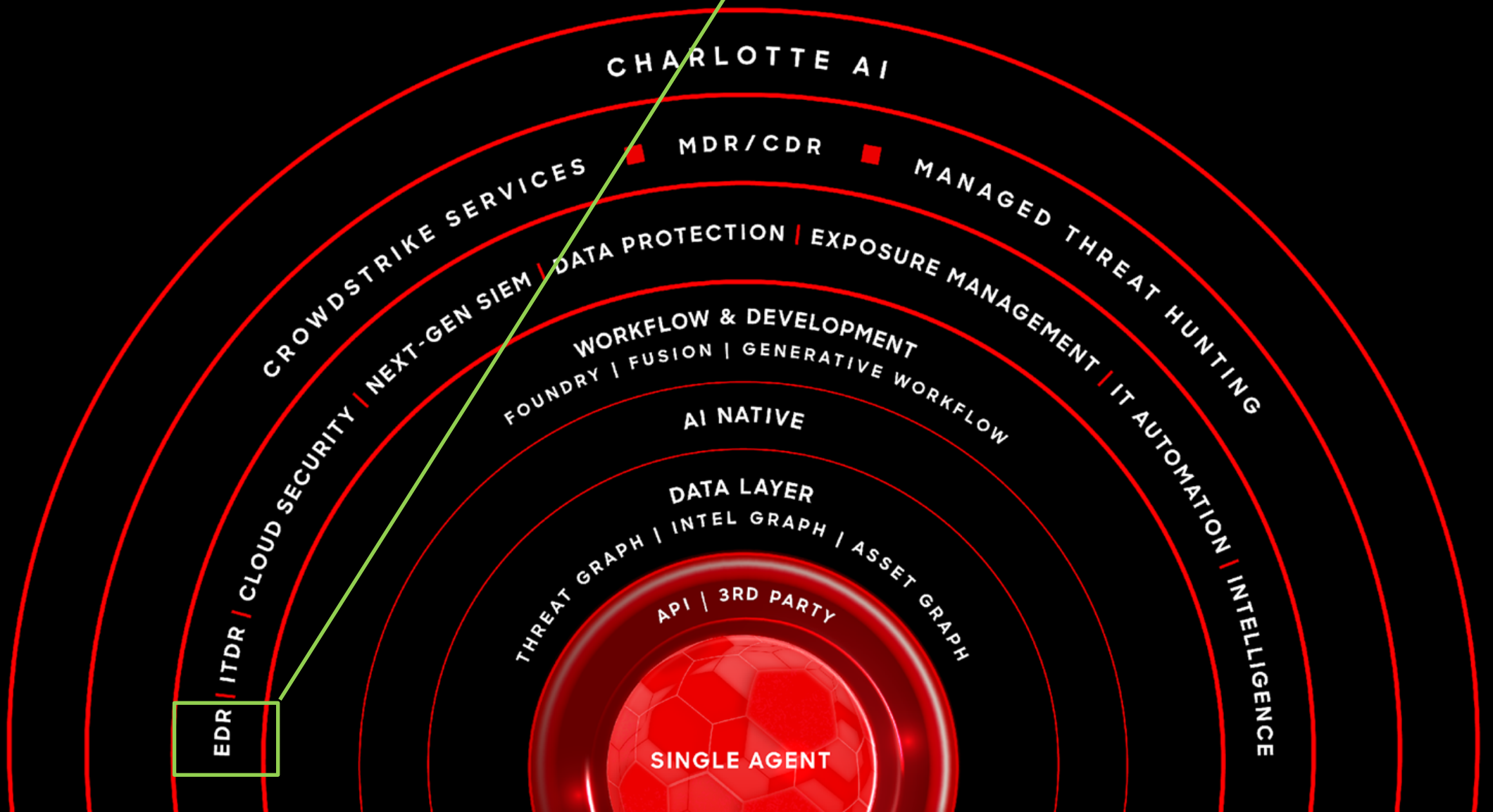


© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

CrowdStrike

The AI-Native Falcon Platform

Let's talk about this piece...

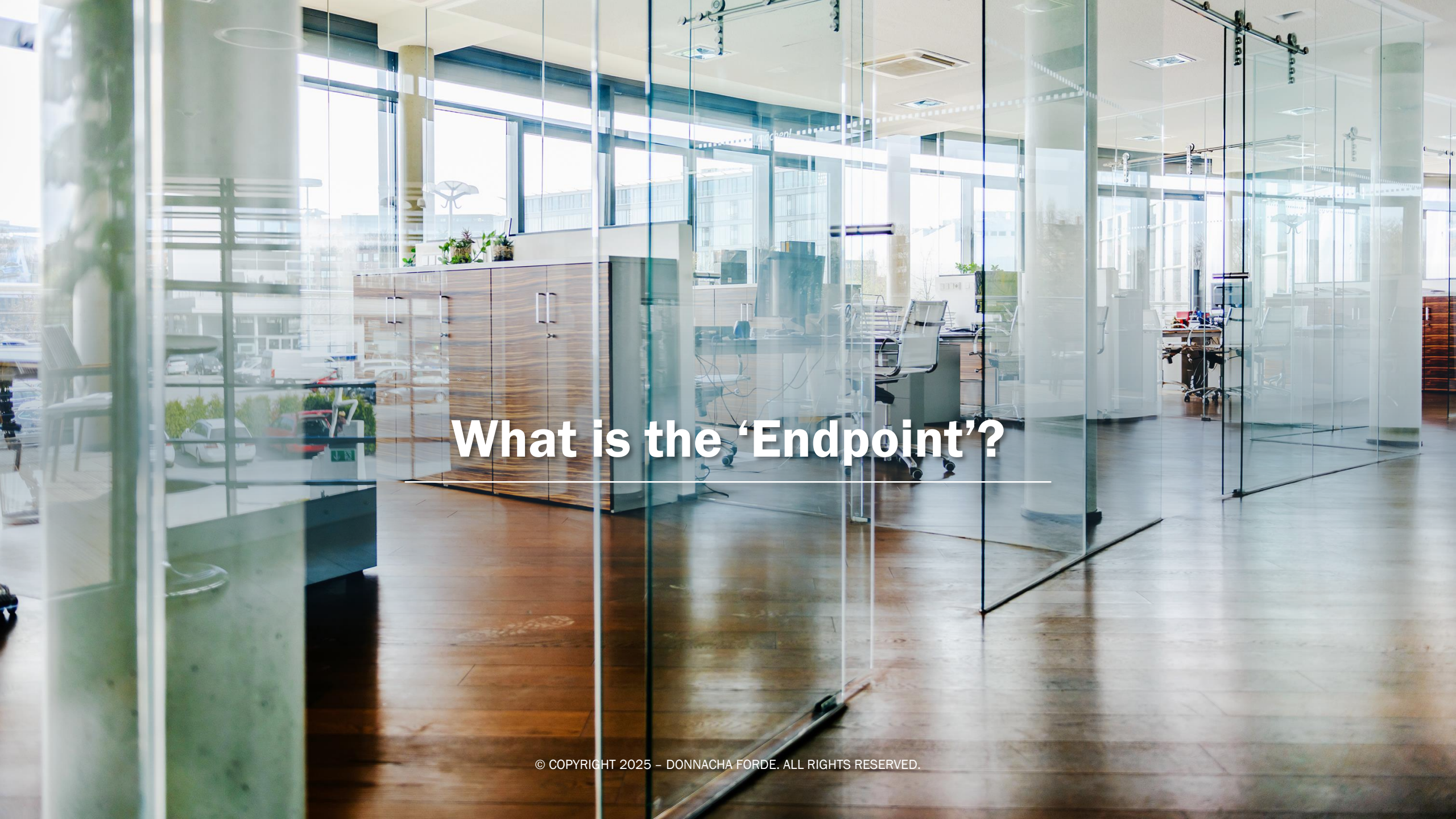


® CrowdStrik

Detection

EDR

© Copyright 2025 – Donnacha Forde. All rights reserved.



What is the ‘Endpoint’?

© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

THE ENDPOINT



Desktop PC



Laptop



Tablet



Mobile



Server



Gaming Device



IoT Device



Smart Home Devices



VMs & Containers



Network

© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

ENDPOINT SECURITY

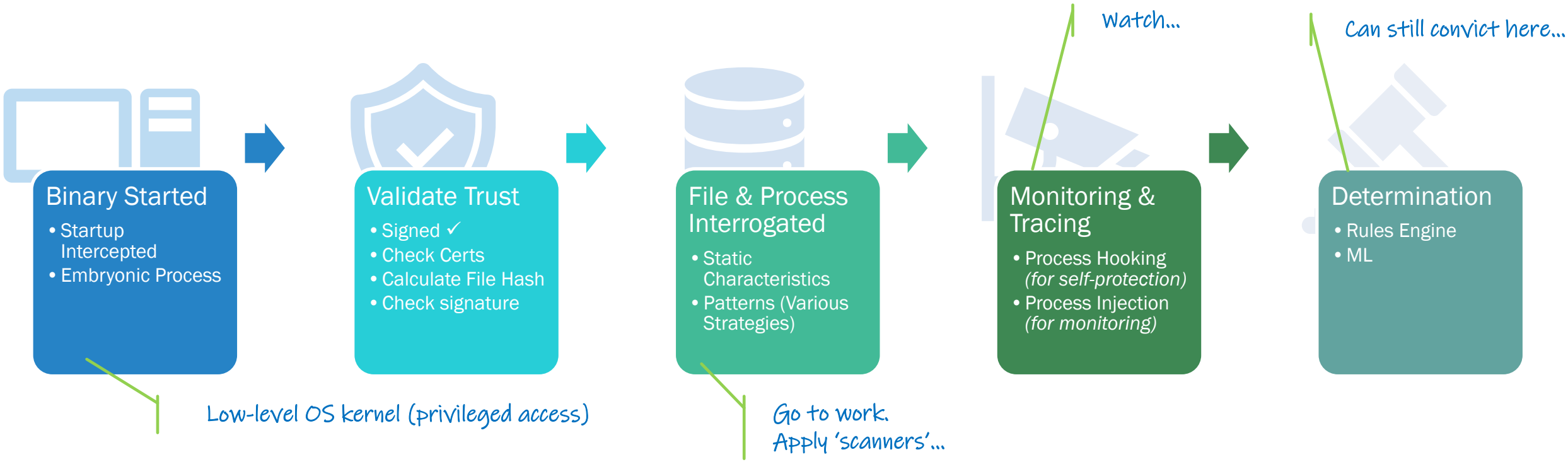
Antivirus (AV) / Antimalware	Data Loss Prevention (DLP) / Data Protection	Ad Blocking
Patch & Vulnerability Management	Password Management	Email protection*
Identity Protection* (IAM)	Endpoint Detection & Response (EDR)	Web Protection
Browser Isolation	Firewall	Network Control/Protection
Intrusion Detection and Prevention (IDP)	VPN	DNS Filtering

*also involve Server/Cloud Technology



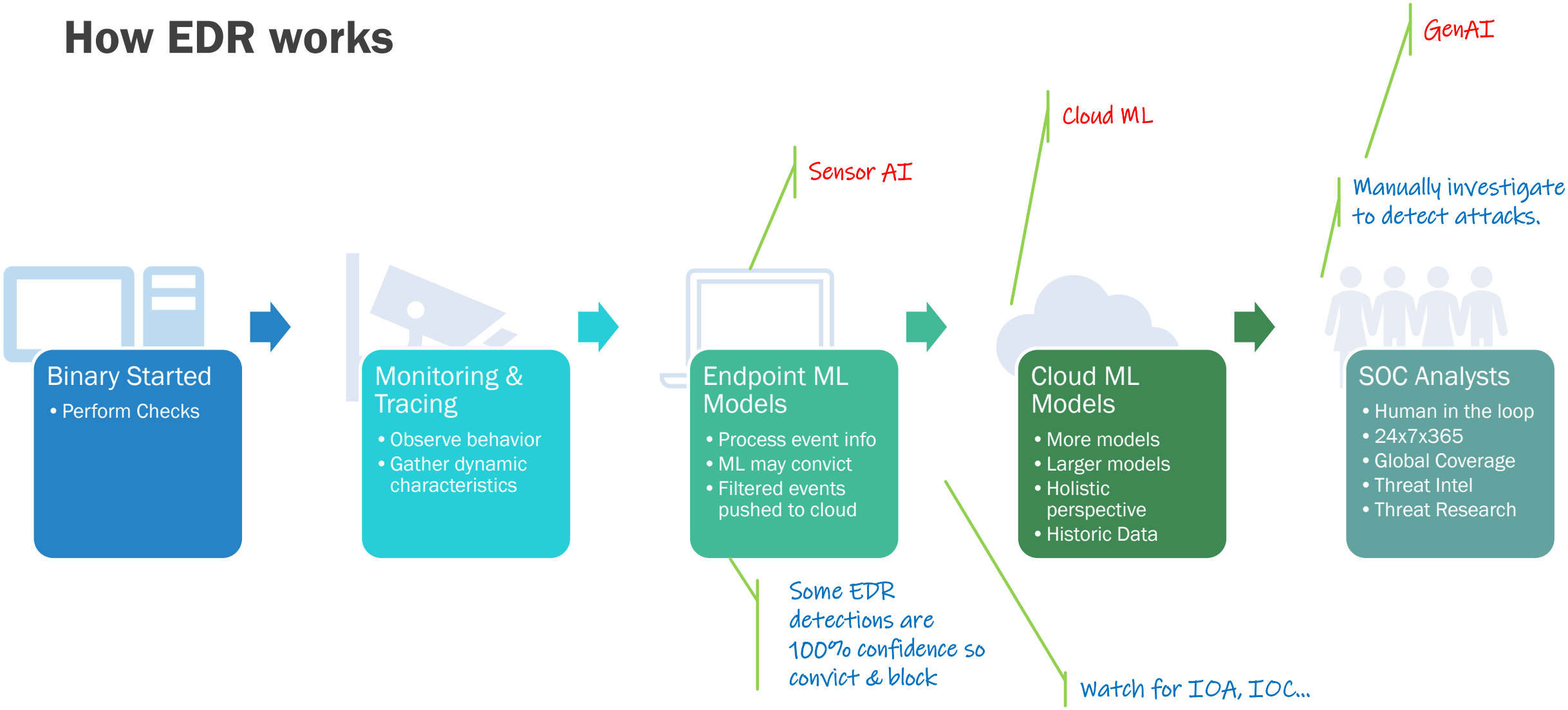
© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

How Traditional AV works



© Copyright 2025 – Donnacha Forde. All rights reserved.

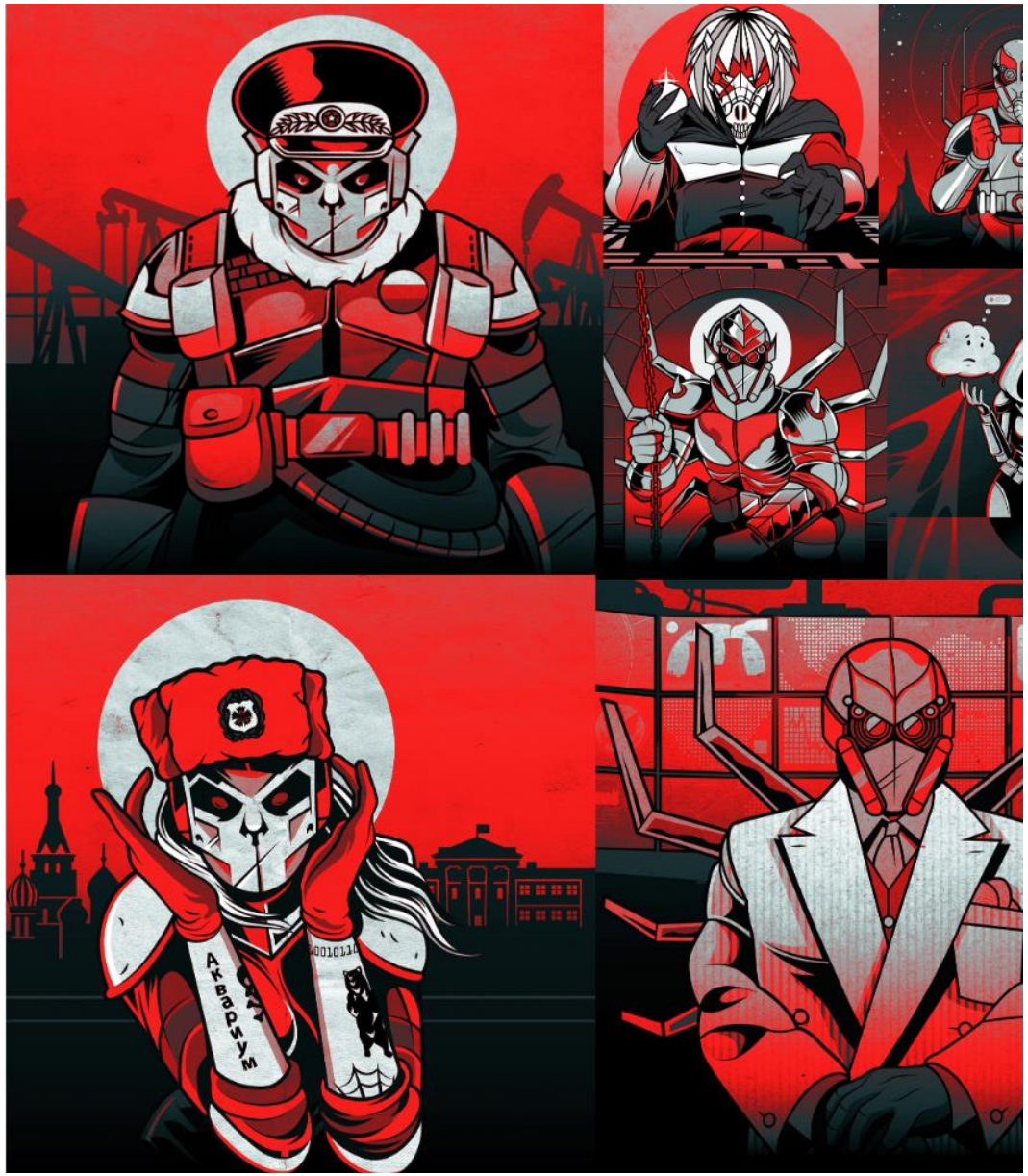
How EDR works



© Copyright 2025 – Donnacha Forde. All rights reserved.

AI in Cybersecurity

© Copyright 2025 – Donnacha Forde. All rights reserved.

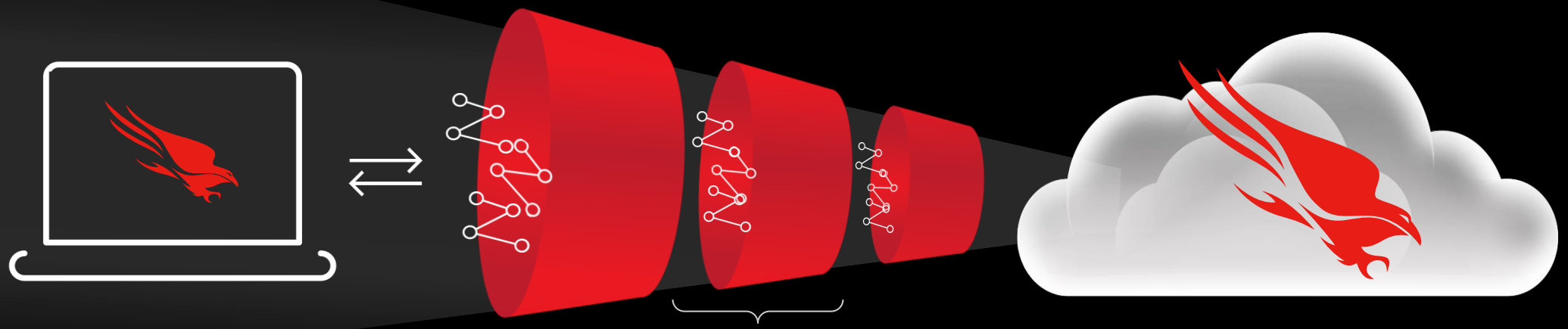


HOW CROWDSTRIKE HAVE APPROACHED AI-NATIVE DETECTION

- AI Powered Malware Classification
- AI Powered Indicators of Attack (IOA)

© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

AI-native detection from the sensor to the cloud



5X

Improved detection when combining on-sensor ML + AI powered IoAs

1. ON THE SENSOR:
ML-Malware Classification (Local File Analysis)

2. AT RUNTIME:
AI-Powered Indicators of Attack (Behavioral Analysis)

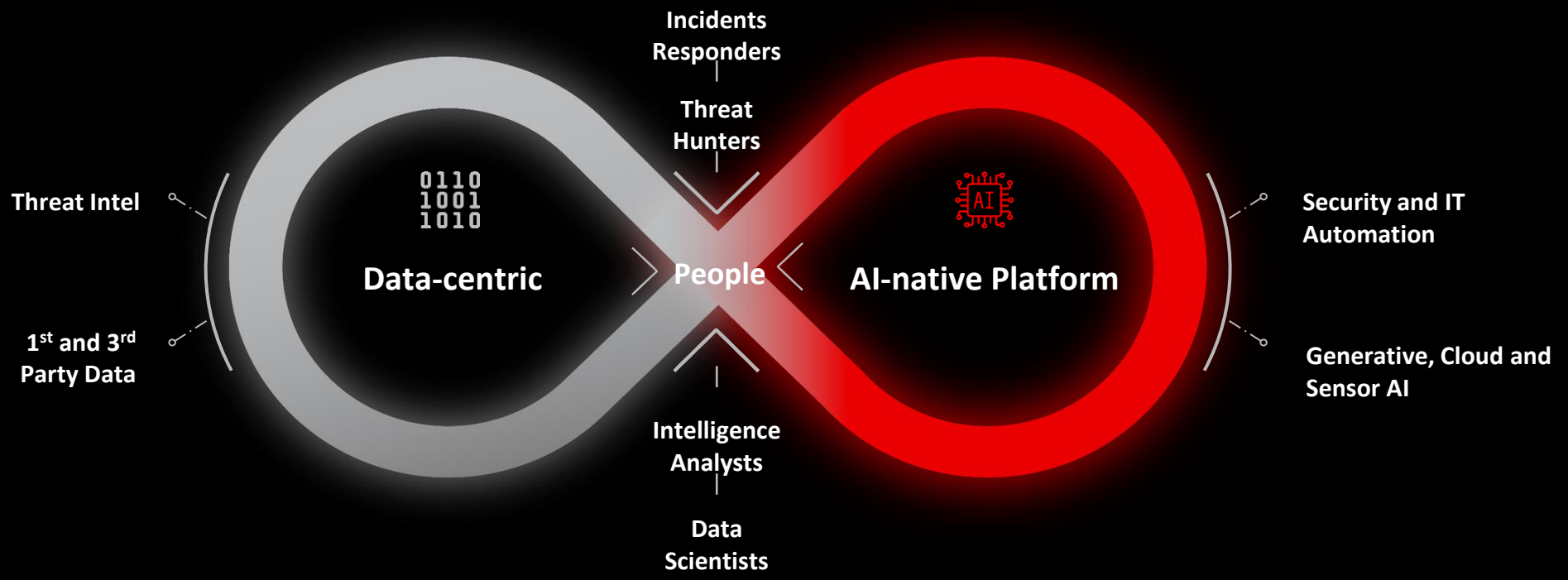
3. IN THE CLOUD:
ML-Malware Classification (Deeper File Analysis)

Signal Composition (On-sensor, runtime, cloud-based ML)

® CrowdStrike, Inc. All Rights Reserved

Great AI begins with great data

The data feedback loop fueling AI



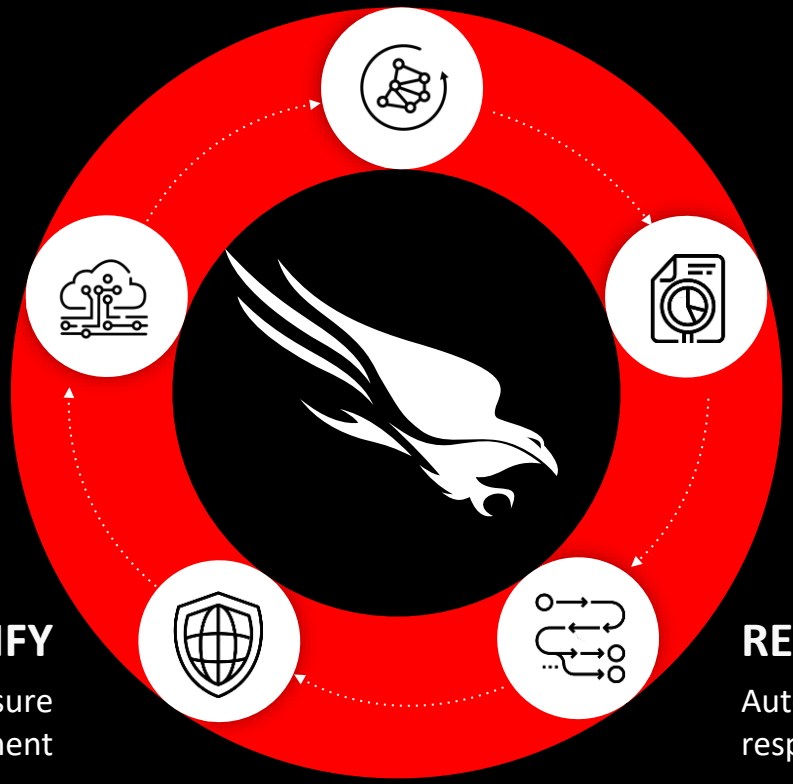
Trillions
Events processed per day

+245
Global Adversaries tracked

800K
Indicators of Compromise (IoCs) issued Per Month

® CrowdStrike, Inc. All Rights Reserved

Elevating the End-to-End Analyst Experience
with an AI-Native Platform



DETECT
AI-powered detection from the sensor to the cloud

INVESTIGATE
Agentic AI-powered triage and investigation

RESPOND
Automated Prevention and accelerated response

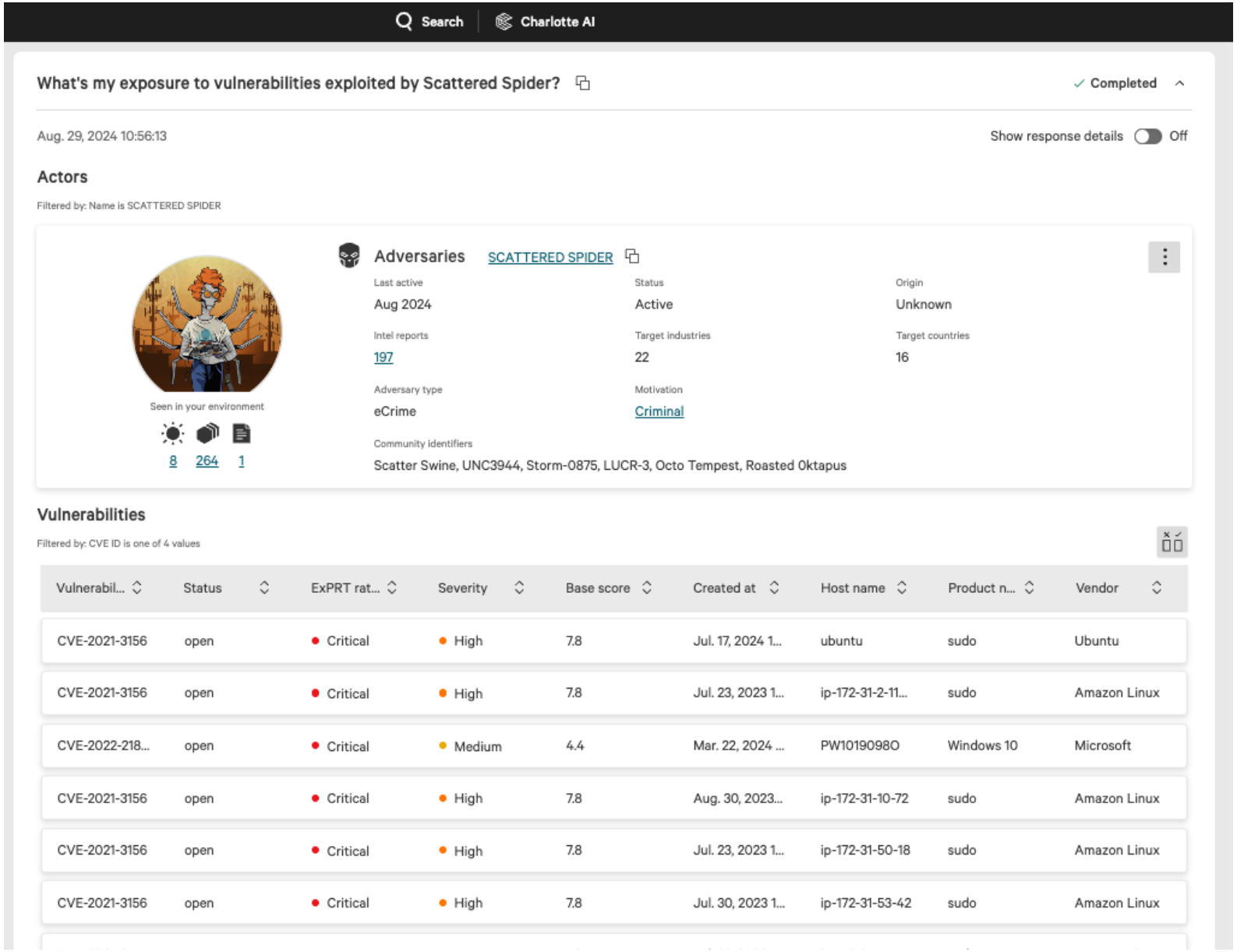
FORTIFY
AI-powered exposure management

INGEST
AI-generated parsing for 3rd Party data ingestion

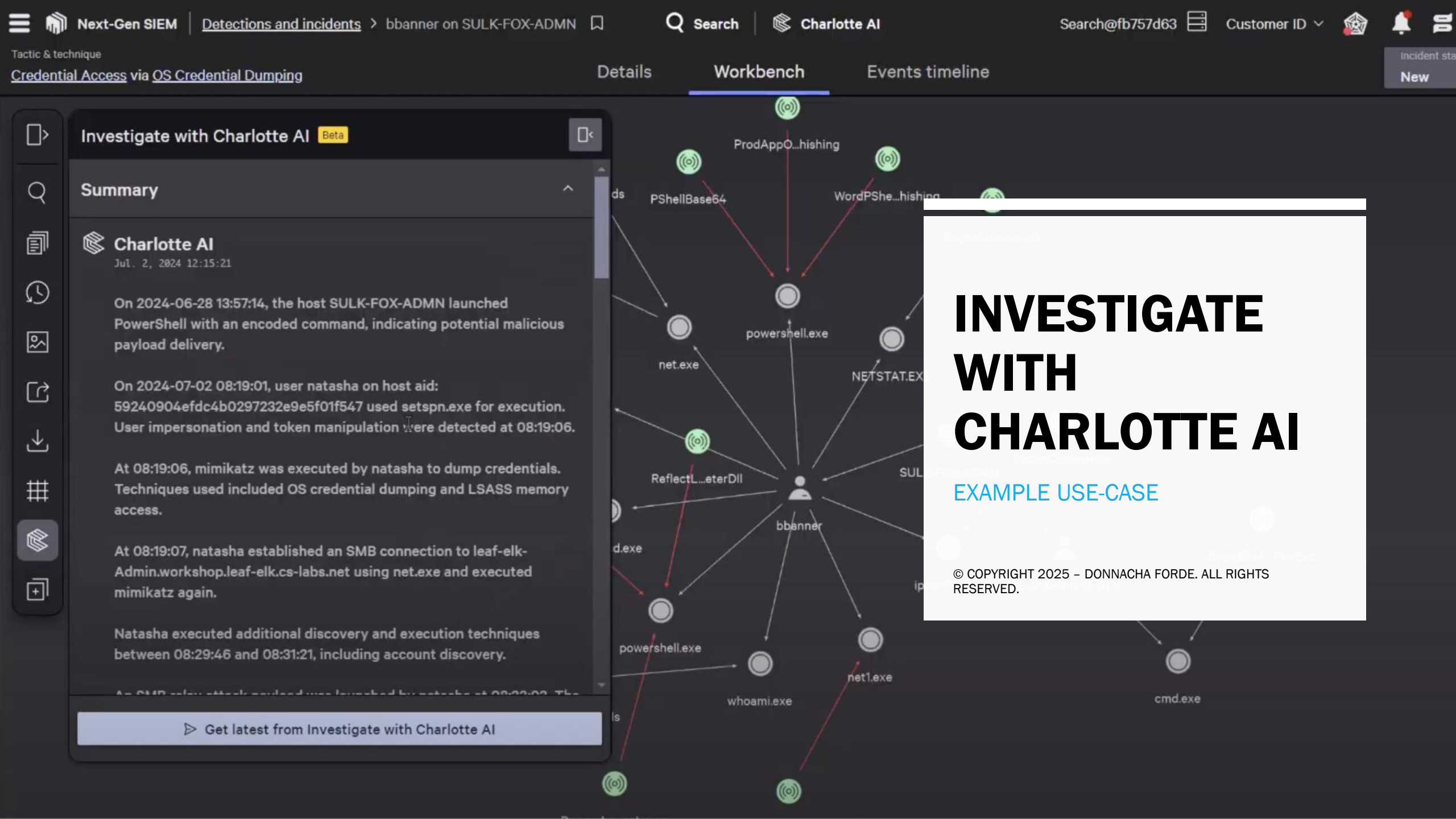
® CrowdStrike, Inc. All Rights Reserved

MEET CROWDSTRIKE'S CHARLOTTE AI

"What's my exposure to vulnerabilities exploited by Scattered Spider?"



© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.



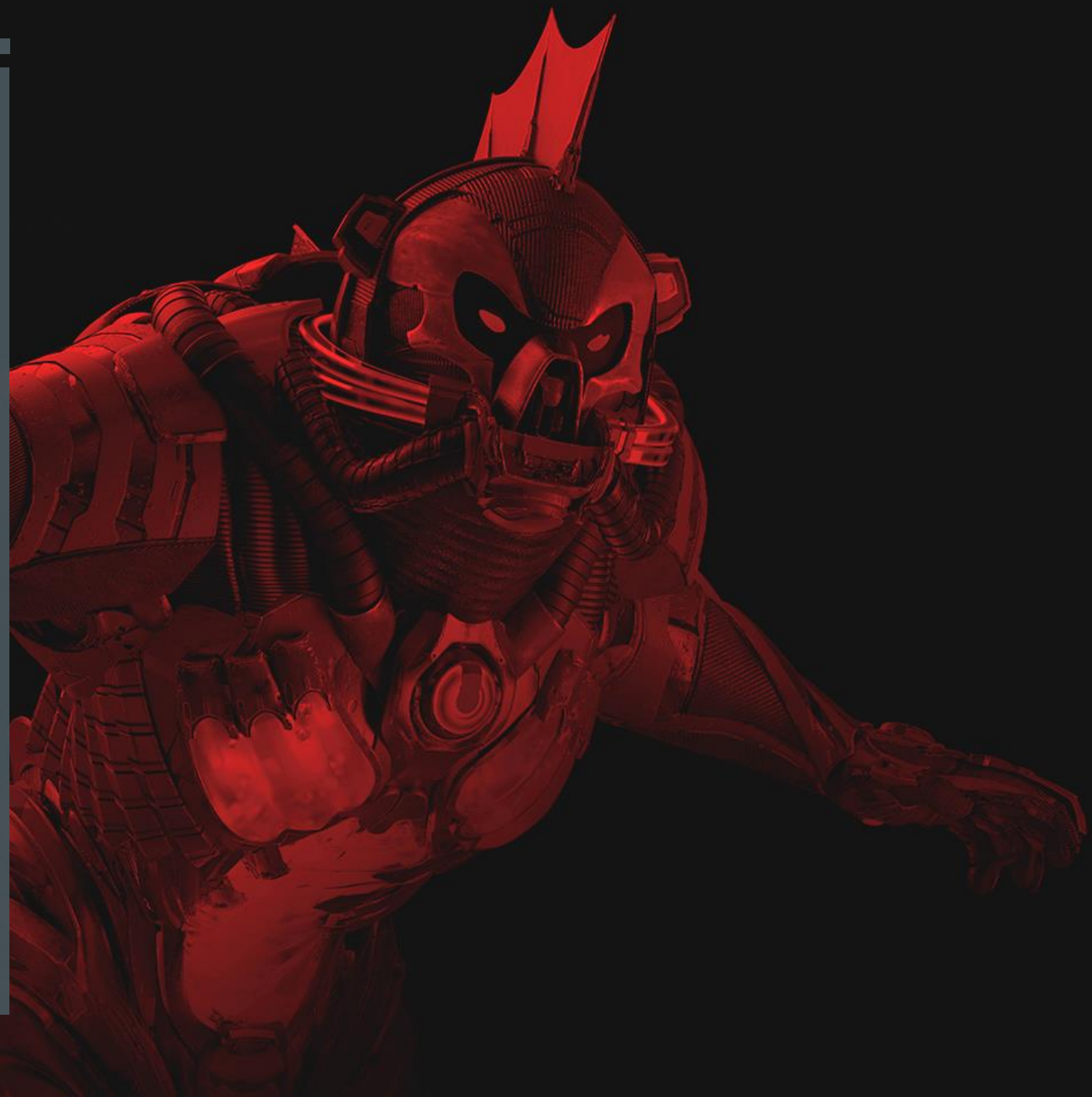
INVESTIGATE WITH CHARLOTTE AI

EXAMPLE USE-CASE

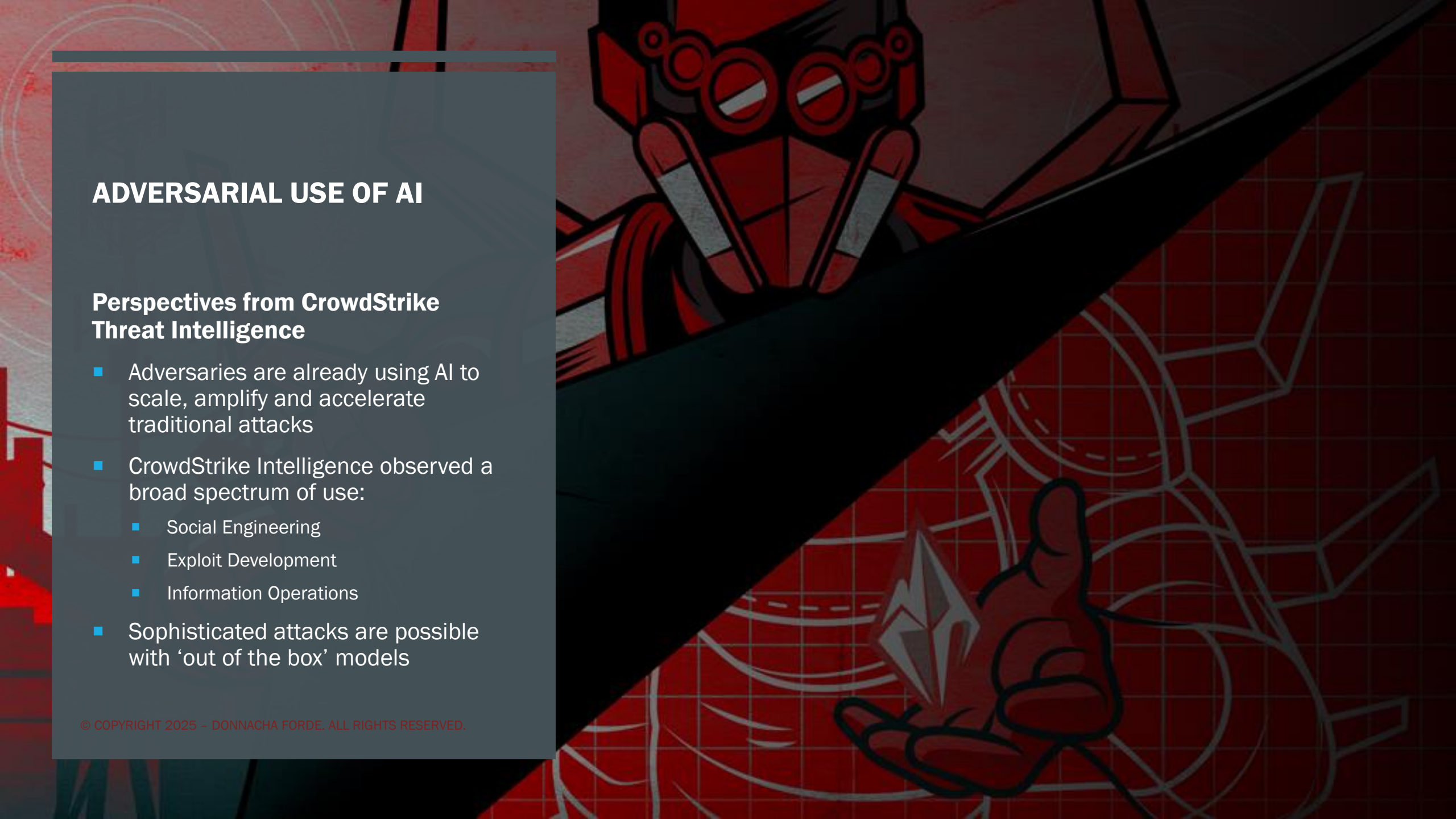
© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

CYBERSECURITY + AI = DOUBLE-EDGED SWORD

AI helps modern security teams to do more and react faster than ever. But, it can also help adversaries scale and accelerate.



© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.



ADVERSARIAL USE OF AI

Perspectives from CrowdStrike Threat Intelligence

- Adversaries are already using AI to scale, amplify and accelerate traditional attacks
- CrowdStrike Intelligence observed a broad spectrum of use:
  - Social Engineering
  - Exploit Development
  - Information Operations
- Sophisticated attacks are possible with ‘out of the box’ models

© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

KEY TAKEAWAYS

- AI use is prevalent in cybersecurity and detection is key.
- There are challenges preventing AI-related attacks.
- There are challenges securing and trusting AI.
- Cybersecurity needs more people.



© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

OWASP Top Ten Risk & Mitigations for LLMs and GenAI



LLM01:2025 Prompt Injection

A Prompt Injection Vulnerability occurs when user prompts alter the...

Read More



LLM02:2025 Sensitive Information Disclosure

Sensitive information can affect both the LLM and its application...

Read More



LLM03:2025 Supply Chain

LLM supply chains are susceptible to various vulnerabilities, which can...

Read More



LLM04:2025 Data and Model Poisoning

Data poisoning occurs when pre-training, fine-tuning, or embedding data is...

Read More



LLM05:2025 Improper Output Handling

Improper Output Handling refers specifically to insufficient validation, sanitization, and...

Read More



LLM06:2025 Excessive Agency

An LLM-based system is often granted a degree of agency...

Read More



LLM07:2025 System Prompt Leakage

The system prompt leakage vulnerability in LLMs refers to the...

Read More



LLM08:2025 Vector and Embedding Weaknesses

Vectors and embeddings vulnerabilities present significant security risks in systems...

Read More



LLM09:2025 Misinformation

Misinformation from LLMs poses a core vulnerability for applications relying...

Read More



LLM10:2025 Unbounded Consumption

Unbounded Consumption refers to the process where a Large Language...

Read More

https://genai.owasp.org/llm-top-10/

© COPYRIGHT 2025 – DONNACHA FORDE. ALL RIGHTS RESERVED.

Thank you

© Copyright 2025 – Donnacha Forde. All rights reserved.

© Copyright 2025 – Donnacha Forde. All rights reserved.